

LAB 7: STATIC CODE ANALYSIS

Cybersecurity Lab course

Federico Marengo, IN2300022

Repositories



- *Repo with known security vulnerabilities:*
 - **OWASP/NodeGoat (Node.js/Express)**
 - An intentionally vulnerable application developed by OWASP to demonstrate OWASP Top 10 security risks in Node.js environments.



- *Repo without known security vulnerabilities:*
 - **pagopa/pagopa-ecommerce-transactions-service (Java/Spring Boot)**
 - A real-world production backend service maintained by the Italian Public Administration in Java and Spring Boot.

Tools

- **SonarQube (WebbApp)**
 - for Static Application Security Testing (SAST)
- **SCA: Trivy (cli)**
 - for Software Composition Analysis (SCA)

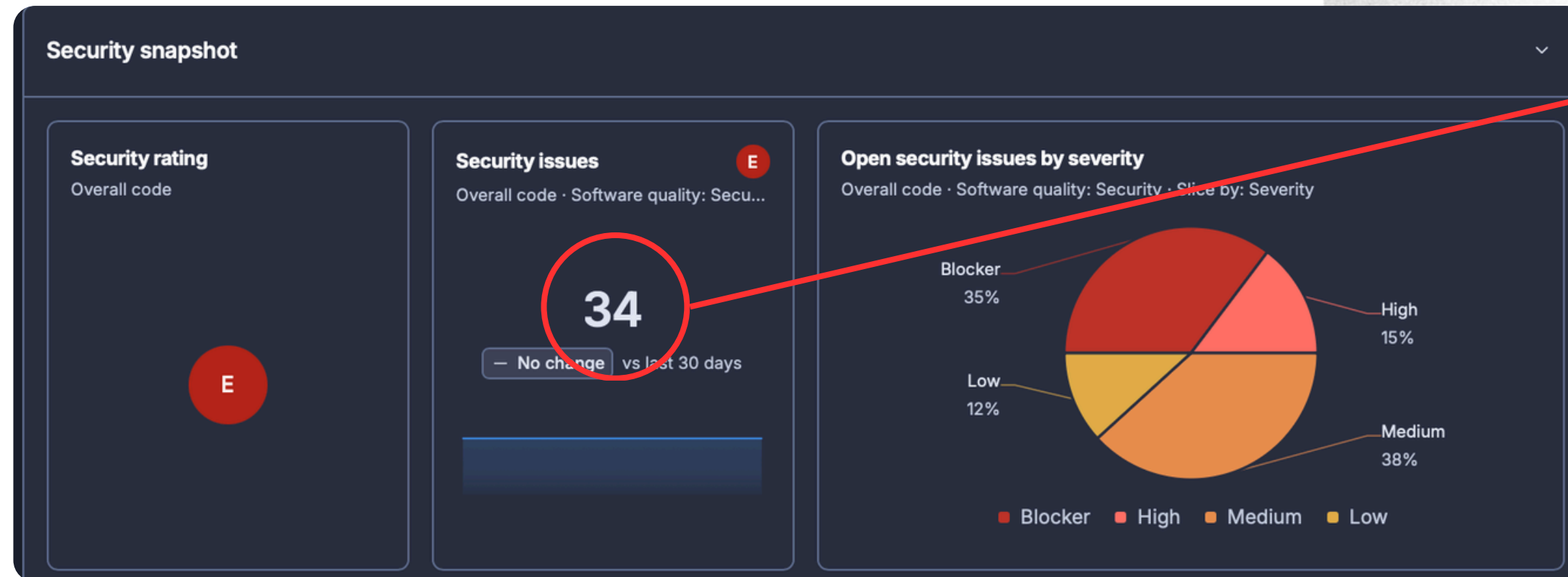


The image features a white background with two large, abstract, light gray shapes in the corners. One shape is in the top-left corner, and the other is in the bottom-right corner. They have soft, organic edges, resembling stylized clouds or liquid droplets.

NODEGOAT

SAST Analysis with SonarCloud

Verify the detection vulnerabilities.



As aspected we find a lot of vulnerabilities

As for example:

☐ Change this code to not construct database queries directly from user-controlled data. Intentionality

Security Blocker cwe +

Open Not assigned L104 • 30min effort • 6 years ago

Vulnerable Code Example

SonarCloud highlighted several Security Hotspots and Vulnerabilities stemming from unsanitized user inputs.

- **NoSQL Injection:** Identified vulnerable patterns in MongoDB query functions (e.g., `getUserByUserName`), where raw user input is passed directly into the query object (`{ userName: userName }`).

The screenshot displays the SonarCloud interface for a vulnerability in the file `app/data/user-dao.js`. The vulnerability is titled "Change this code to not construct database queries directly from user-controlled data." and is categorized as a "Security" issue with a "Blocker" severity. It references the rule `jssecurity:S5147` and indicates that "NoSQL operations should not be vulnerable to injection attacks". The issue is located on line 104 of the file, where the `findOne` method is called with a query object that includes `userName` as a property. A red arrow points from the text in the list to this line of code. The interface also shows a sidebar with tags like "cwe" and "Line affected L104", and a bottom section with tabs for "Where is the issue?", "Why is this an issue?", "How can I fix it?", "Activity", and "More info".

Intentionality | Not complete

Change this code to not construct database queries directly from user-controlled data.

NoSQL operations should not be vulnerable to injection attacks [jssecurity:S5147](#)

Software qualities impacted: Security Blocker

Open in IDE Not supported

Open Not assigned

Where is the issue? Why is this an issue? How can I fix it? Activity More info

app/data/user-dao.js

Show 97 lines Show all lines

```
98  jesus...      usersCol.findOne({
99                _id: parseInt(userId)
100             }, callback);
101             });
102             };
103             this.getUserByUserName = (userName, callback) => {
104                 usersCol.findOne({
105                     userName: userName
106                 }, callback);
107             };
108             this.getNextSequence = (name, callback) => {
```

Change this code to not construct database queries directly from user-controlled data.

Tags: cwe +

Line affected: L104

Effort: 30 min

Introduced: 6 years ago

See all issues in this file

SCA Analysis with Trivy

Scan third-party libraries dependencies

Detected a high volume of known CVEs, including **CRITICAL** and **HIGH** severity flaws.

Report Summary

Target	Type	Vulnerabilities
package-lock.json	npm	87

Legend:

- '-': Not scanned

- '0': Clean (no security findings detected)

package-lock.json (npm)

Total: 87 (UNKNOWN: 0, LOW: 11, MEDIUM: 21, HIGH: 44, CRITICAL: 11)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
body-parser	CVE-2024-45590	HIGH	fixed	1.18.3	1.20.3	body-parser: Denial of Service Vulnerability in body https://avd.aquasec.com/nvd/cve-2024-45590

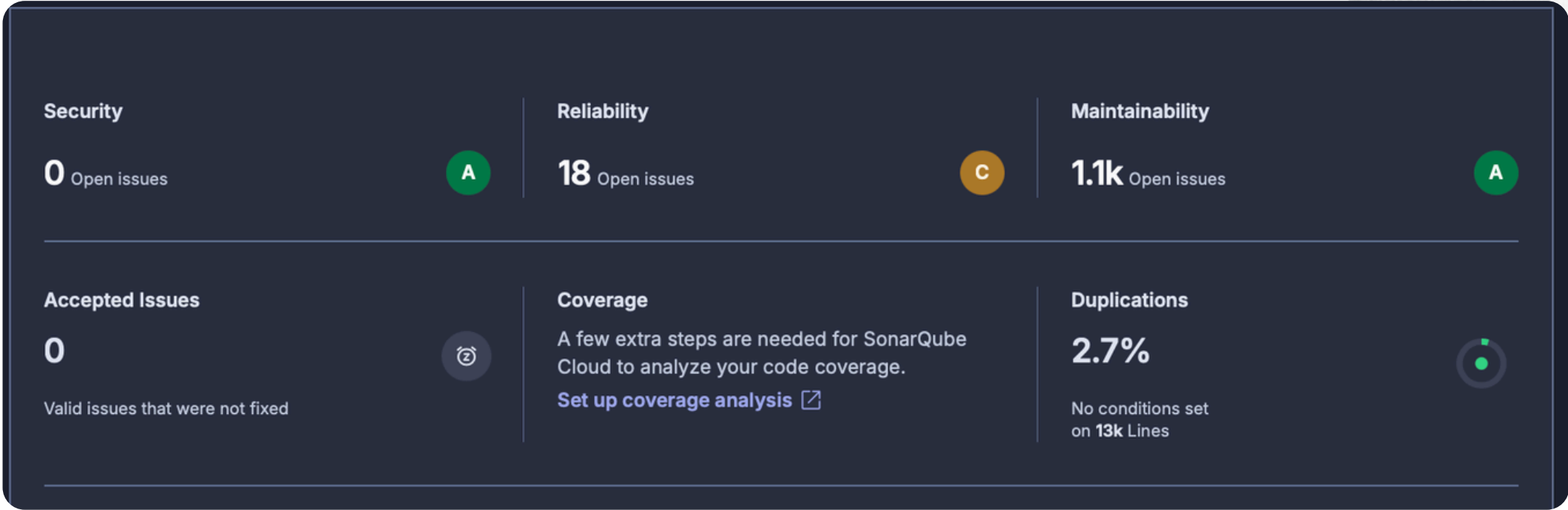
set-value	CVE-2019-10747	CRITICAL		0.4.3	2.0.1, 3.0.1	nodejs-set-value: prototype pollution in function se https://avd.aquasec.com/nvd/cve-2019-10747
t-value	CVE-2021-23440	HIGH			4.0.1, 2.0.1, 3.0.3	nodejs-set-value: type confusion allows bypass of CVE-2019-10747 https://avd.aquasec.com/nvd/cve-2021-23440
t-value	CVE-2019-10747	CRITICAL		2.0.0	2.0.1, 3.0.1	nodejs-set-value: prototype pollution in function se https://avd.aquasec.com/nvd/cve-2019-10747



PAGOPA-ECOMMERCE-TRANSACTIONS- SERVICE

SAST Analysis with SonarCloud

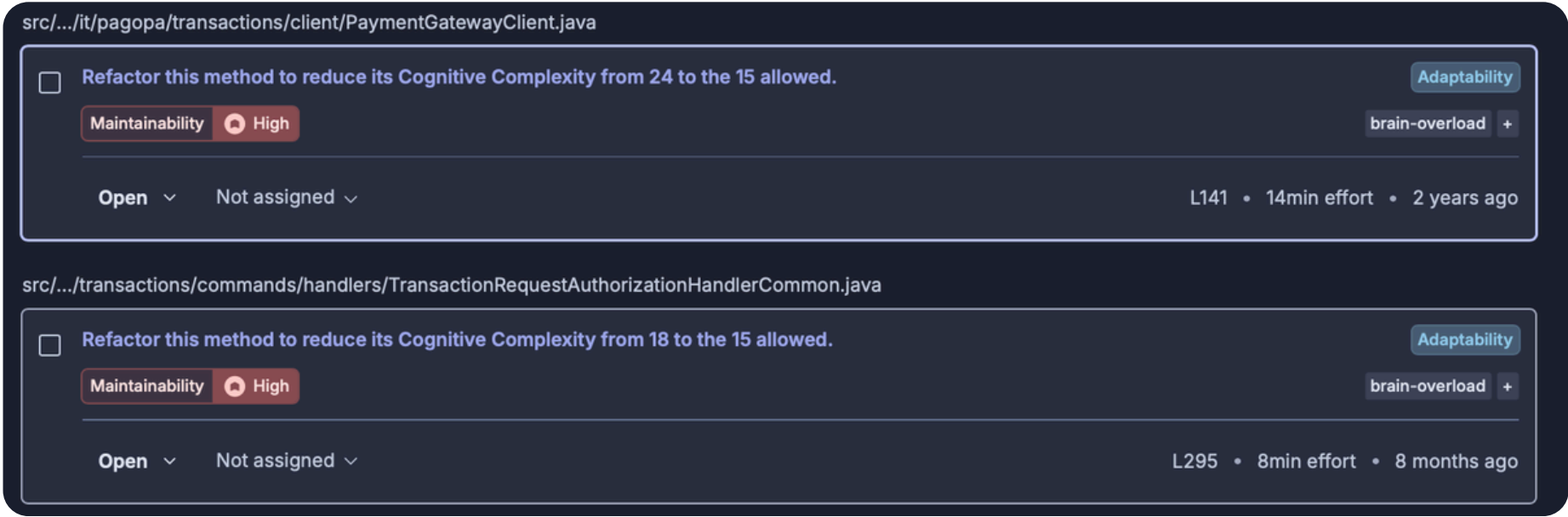
Verify the detection vulnerabilities:



0 Open Security Issues directly in the business logic code. → **Rating A**

18 minor open reliability issues.

As for example:



Main issues are Code Smells related to maintainability rather than security.

SCA Analysis with Trivy

Scan third-party dependencies declared in **pom.xml**

Report Summary

Target	Type	Vulnerabilities
pom.xml	pom	3

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

pom.xml (pom)

Total: 3 (UNKNOWN: 0, LOW: 0, MEDIUM: 1, HIGH: 2, CRITICAL: 0)

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title	
io.opentelemetry:opentelemetry-api	CVE-2026-45292	MEDIUM	fixed	1.60.1	1.62.0	opentelemetry-java: opentelemetry-api: opentelemetry-extension-trace-propagators: OpenTelemetry Java: Denial of Service due to unbounded memory... https://avd.aquasec.com/nvd/cve-2026-45292	
org.springframework.boot:spring-boot-starter-actuator	CVE-2026-22731	HIGH		3.4.5	3.5.12, 4.0.4	Spring Boot: Spring Boot: Authentication bypass via misconfigured Health Group additional path... https://avd.aquasec.com/nvd/cve-2026-22731	
	CVE-2026-22733				4.0.4, 3.5.12	Spring Boot has an Authentication Bypass under Actuator CloudFoundry endpoints https://avd.aquasec.com/nvd/cve-2026-22733	

- Trivy identified 3 third-party dependency vulnerabilities, 2 of which are rated **HIGH severity**.
- As highlighted by the scan, the application uses outdated library versions where fixes are already available.